

摘要：

研究人员借助Claude Opus 5，在72小时内将一个图像处理漏洞扩展为完整攻击链，最终获取OpenAI员工ChatGPT账户及内部GitHub访问权限。事件显示，AI正在显著压缩高级漏洞利用的开发成本，同时暴露AI代理作为企业权限枢纽带来的新安全风险。

一场颇具讽刺意味的安全事件正在引发关注：**研究人员借助Anthropic最新的Claude Opus 5，将一个图像处理漏洞逐步扩展为完整攻击链，最终获取了一名OpenAI员工的ChatGPT账户访问权限，并进一步触及OpenAI内部GitHub环境。**这意味着，AI正在让网络安全攻防骤然升温，高级漏洞利用的门槛和成本正被快速压低。

安全初创公司Hacktron AI的研究人员本周披露了上述行动。据《华尔街日报》近日报道，该团队获得了一名OpenAI员工ChatGPT账户的访问权限，并具备读取和提交OpenAI私有软件变更的能力。Hacktron表示，研究人员于7月25日通过OpenAI的Bugcrowd漏洞赏金计划完成披露，OpenAI当天确认已修复其侧的漏洞，并向研究团队支付了6500美元赏金。

此次事件的关键并不只是一个漏洞被攻破，而是多个安全边界被依次串联起来：第三方基础设施中的漏洞、联合身份认证缺陷，以及与企业内部系统深度连接的AI代理账户。对于正在大规模部署AI代理的企业而言，**这种攻击路径意味着，原本分散的安全风险可能被AI账户串联成一条完整的权限链。**

攻击链全貌：从图像上传到内部代码库

此次攻击的初始入口是OpenAI社区论坛community.openai.com，该论坛基于Discourse平台运行。

Hacktron发现，上传至Discourse的HEIC和HEIF图像会经过ImageMagick处理，并由libheif解码。研究人员指出，相关环境中的libheif版本存在堆缓冲区溢出漏洞，可被开发为远程代码执行（RCE）漏洞。Discourse随后确认该漏洞，并于7月28日发布安全公告，将其CVSS评分定为8.8，同时完成补丁修复并加强图像处理沙箱。

但论坛服务器被攻破只是第一步。Hacktron随后发现OpenAI单点登录（SSO）实现中的另一处缺陷，使研究人员能够将论坛环境的控制权进一步转化为对ChatGPT和Codex账户的访问权限，其中包括OpenAI员工账户。**研究人员强调，这一权限提升并非Discourse漏洞，而是OpenAI身份认证层面的独立问题。**

进入员工Codex账户后，研究人员发现该账户已连接至OpenAI的GitHub组织，并指令Codex在OpenAI内部monorepo（openai/openai）中创建一个无害的pull request，以证明账户入侵能够进一步延伸至开发者基础设施，同时避免读取敏感源代码。

Claude Opus 5将漏洞利用压缩至72小时内

此次事件另一个值得关注的地方，是AI模型直接参与了漏洞利用程序的开发。

Hacktron表示，研究人员最初使用Claude Opus 4.8分析存在漏洞的libheif并尝试开发利用程序，但在地址空间布局随机化（ASLR）开启的情况下难以稳定复现。Anthropic于7月24日发布Claude Opus 5，并将其定位为在长时运行代理和编程任务方面的重要升级。



切换至Opus 5后，模型在数小时内生成了可用的ARM64漏洞利用程序，随后又将其适配至Discourse所使用的x86-64及jemalloc环境。**Hacktron称，从发现漏洞到获得OpenAI代码库访问权限，整个过程耗时不足72小时。**

这一案例显示，AI代理正在压缩高级漏洞利用的时间成本。过去，内存损坏漏洞从发现到形成稳定利用程序通常需要大量逆向分析、调试和开发工作，而前沿编程模型已经能够在人工指导下承担其中相当一部分工作。

AI代理账户成为新的权限枢纽

相比单个漏洞，此次事件对企业安全架构更深层的影响，可能来自AI代理账户所处的位置。

Hacktron指出，**受影响的ChatGPT或Codex账户可能连接GitHub、Slack、Outlook、Gmail及Google Drive等多个服务。一旦AI账户遭到入侵，攻击者可能进一步继承与其关联的下游系统权限。**AI账户由此从单一应用凭证，变成连接代码、通信和企业数据的身份与授权枢纽。

Hacktron还将此次OpenAI事件列为更大范围“HEIF Heist”研究的一部分，并称同一路线还延伸至Slack、Meta、Zoom、Shopify、GitHub Enterprise等平台。不过，目前公开披露的技术细节和厂商确认信息主要集中在OpenAI案例。

对于企业安全团队而言，**这一事件提示了几项防护重点：隔离不可信文件处理管道，及时修补底层依赖漏洞，收紧联合身份认证的信任范围，并按照接近特权账户的标准管理AI代理的凭证与权限。**随着AI代理进一步接入企业内部系统，一个AI账户失守的影响可能沿着其连接的权限链向下游扩散。

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

 **限时权益申领**

* 体验资格每人限申领一次

扫码 >
免费领取

VIP会员·7天畅读卡 | 大师课·入门串讲



限免

👍 90 ★ 收藏

分享到:  

写评论

请发表您的评论

 表情  图片

发表评论

